SIMATS ENGINEERING

CSA6303- Threat Intelligence and Network Security

A1-Malware Analysis Assignment

Assessment Questions

Subject	Threat Intelligence	**Total Marks**	50
Questions	10 (all compulsory)	**Marks per Question**	5
REg.No	192465054	**Name**	A Abhinava Reddy
Faculty	Dr.V.Parthipan	**Slot**	A

Instructions: Answer all questions. Each question carries 5 marks. Support answers with examples and diagrams where appropriate.

CO3: Perform threat analysis using intelligence models and utilize industry tools for monitoring and detection.

Code of Conduct:

I A Abhinava Reddy,192465054(Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment. I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of Student

A Abhinava Reddy

Malware Analysis, Threat Intelligence and Log Investigation

Scenario-Based Answers (Questions 1 to 10)

Question 1: Malware Analysis Using Static Techniques

A security analyst receives a suspicious executable file attached to a phishing email. Before running the file, the analyst wants to examine its properties, file hash, strings, and imported functions. Explain how static malware analysis can help identify suspicious characteristics and assess the potential risk without executing the file.

Introduction

Static analysis examines a file's code and structure without running it. Because the sample never executes, there is no risk of infecting the system, which makes it the safest first step for a file received through phishing. It answers the questions "what is this file, what could it do, and has it been seen before?"

Step 1: Safe handling

- Work on an isolated analysis machine or VM with no network access; never double-click the file.
- Keep the sample in a password-protected archive or rename it (for example to .bin) to prevent accidental execution.

Step 2: File identification and properties

- Check the true file type from its magic bytes (for example "MZ" for a Windows PE file) using the file command or TrID, and compare it with the extension. A file named invoice.pdf.exe is a classic phishing trick.
- Note size, timestamps, icon and digital signature. A missing, invalid or stolen certificate is a warning sign.

Step 3: File hashing

- Compute MD5, SHA-1 and SHA-256 hashes (certutil, sha256sum, HashMyFiles).
- Look the hash up in VirusTotal, MalwareBazaar or a threat-intelligence platform to see whether it is known malware, its family and its detection ratio. A hash is a unique fingerprint, so a match gives a fast, reliable identification.
- Fuzzy hashes (ssdeep) and the import hash (imphash) help find variants whose exact hash has changed.

Step 4: Strings extraction

Tools such as strings or FLOSS pull readable text from the binary. Useful findings include URLs, domains and IP addresses (C2 servers), registry paths (persistence), file names and paths, command lines (PowerShell, cmd), ransom-note text, user-agent strings, mutex names, embedded passwords, and names of Windows API functions. A file with almost no readable strings may be packed or encrypted.

Step 5: PE header and section analysis

- Tools: PEStudio, PE-bear, CFF Explorer, Detect It Easy.
- Compile timestamp (a fake or very recent date), unusual section names (UPX0, .aspack), a large difference between virtual and raw section size, and high entropy (above about 7) all indicate packing or encryption.

- Embedded resources may hide a second-stage executable or script.

Step 6: Imported functions (Import Address Table)

The imports reveal the capabilities the program intends to use:

Imported API examples	What it suggests
VirtualAlloc, WriteProcessMemory, CreateRemoteThread	Process injection or code injection
URLDownloadToFile, InternetOpen, WinHttpSendRequest, WSAStartup	Downloading files or network communication (C2)
RegSetValueEx, CreateService, SetWindowsHookEx	Persistence in registry or services; hooking
GetAsyncKeyState, GetClipboardData	Keylogging or data theft
CryptEncrypt, CryptGenKey	File encryption (possible ransomware)
IsDebuggerPresent, GetTickCount, Sleep	Anti-debugging and anti-analysis tricks

Very few imports, or only LoadLibrary and GetProcAddress, suggests the real imports are resolved at run time to hide them.

Step 7: Deeper code inspection and signatures

- Disassemble or decompile with Ghidra or IDA to read suspicious routines (decryption loops, hard-coded addresses) without running them.
- Scan with YARA rules and antivirus engines to match known malware patterns.

Risk assessment

The analyst combines the evidence: a known-malicious hash, mismatched file type, packing, hard-coded C2 addresses and injection or persistence APIs raise the risk to high; a signed, clean, well-known file lowers it. The result decides whether the file is blocked, deleted or sent for dynamic analysis, and the IOCs (hashes, domains, IPs) are added to email, endpoint and network defences.

Limitations

Static analysis cannot show actual runtime behaviour, and packed or obfuscated code can hide its intent, so it is normally followed by dynamic analysis.

Question 2: Malware Analysis Using Dynamic Techniques

An organization suspects that an employee has downloaded a malicious program that may modify system files and communicate with an external server. Explain how dynamic malware analysis can be performed in an isolated virtual environment to observe the program's behavior and identify potential Indicators of Compromise (IoCs).

Introduction

Dynamic analysis runs the suspicious program in a controlled environment and records what it does: files it changes, registry keys it writes, processes it starts and servers it contacts. It reveals real behaviour that static analysis can miss because of packing or obfuscation.

Step 1: Build a safe, isolated lab

- Use a virtual machine (VMware or VirtualBox) running a typical Windows image, with a clean **snapshot** taken before each run so the machine can be restored.
- Disable shared folders, clipboard sharing and drag-and-drop, and keep the VM on a host-only or isolated network so the malware cannot reach the real network.
- Simulate the internet with INetSim or FakeNet-NG on a second VM, which answers DNS, HTTP and other requests so the malware reveals its network behaviour safely.

Step 2: Prepare monitoring tools

Tool	Purpose
Process Monitor and Process Explorer	File, registry and process activity; process tree and loaded modules
Regshot	Before-and-after snapshots of the registry and file system
Wireshark, FakeNet-NG, Fiddler	Capture DNS requests, IP addresses, ports, protocols and HTTP traffic
Autoruns, Sysmon	Persistence locations; detailed process, network and file events
Sandboxes (Cuckoo, ANY.RUN, Joe Sandbox)	Automated execution with behaviour reports and screenshots

Step 3: Execute and observe

1. Take the baseline (Regshot first shot, snapshot, start Procmon and Wireshark).
2. Run the sample (with administrator rights if needed) and let it run for several minutes, interacting with the system where required.
3. Observe **file-system changes:** dropped or modified files, changes to system files, files created in Temp, AppData or System32.
4. Observe **registry changes:** new Run keys, services or settings that provide persistence.
5. Observe **process behaviour:** child processes, injection into legitimate processes, scheduled tasks created.
6. Observe **network behaviour:** DNS lookups, connections to external IPs, beaconing intervals, data uploaded, files downloaded.
7. Take the second Regshot, compare and save all logs and the PCAP.

Step 4: Identify the Indicators of Compromise

IoC type	Examples gathered
File indicators	Hashes of the sample and dropped files, file names and paths, modified system files
Registry indicators	Run keys, service entries, changed security or proxy settings
Process indicators	Process names, command lines, injected processes, mutex names, scheduled tasks
Network indicators	Domains, IP addresses, URLs, ports, user-agent strings, beacon intervals, certificates

Step 5: Precautions and wrap-up

- Some malware detects virtual machines or sandboxes and stays inactive; analysts hide VM artefacts, add user activity and vary the run time.
- After analysis, revert to the clean snapshot and never reuse an infected VM.
- Feed the IoCs to the SIEM, EDR, firewall and DNS filters, and document the behaviour in a report.

Question 3: Malware Investigation Using a Threat Intelligence Platform

A company's security team discovers a suspicious file on an employee's computer. The file hash appears in a threat intelligence platform associated with a known malware family. Explain how the analyst can use threat intelligence sources to investigate the file, assess the reliability of the information, and recommend suitable containment measures.

Introduction

Threat intelligence (TI) is evidence-based knowledge about threats, including indicators, techniques, actors and mitigations. It lets an analyst learn quickly what the file is, what it does and how to respond, rather than analysing it from scratch.

Step 1: Investigate the file using TI sources

- Search the SHA-256 hash in VirusTotal, MalwareBazaar, Hybrid Analysis, AlienVault OTX, MISP and any commercial platform (Recorded Future, Anomali).
- Record the malware family, detection ratio, first and last seen dates, file type and tags, and behaviour reports from sandboxes.
- Collect related IOCs: contacted domains and IPs, dropped files, mutexes, registry keys and linked hashes.
- Identify the associated threat actor, campaign, targeted sectors and the ATT&CK techniques used, which show what else the attacker may have done.
- **Pivot:** use each related indicator to find more (other domains on the same IP, other samples with the same imphash) and then search the company's own logs, EDR and SIEM for them to find other infected machines.

Step 2: Assess the reliability of the information

Not all intelligence is equally trustworthy. The analyst should judge both the source and the information, for example with the Admiralty (NATO) grading system, where source reliability is rated A to F and information credibility 1 to 6.

Factor	Question to ask
Source reputation	Is the source a trusted vendor, CERT, ISAC or community feed with a good track record?
Corroboration	Do several independent sources report the same hash, family and behaviour?
Timeliness	How recent is the report? Old indicators such as reused IPs may no longer be valid.
Relevance and context	Does the malware and its targeting fit our systems and sector?
Confidence and detail	Is there a stated confidence level, sandbox evidence and a TLP marking?
False-positive risk	Could the hash belong to a legitimate or dual-use tool, or have few detections?

Where confidence is low, the analyst verifies independently, for example by examining the file in a sandbox, before taking disruptive action.

Step 3: Recommended containment measures

- **Isolate** the affected computer from the network (EDR network isolation) while preserving memory and disk evidence.
- **Block** the hash, domains and IPs at the endpoint, proxy, DNS filter and firewall.

- **Contain credentials:** disable or reset passwords of the affected user and any accounts used on that machine, and revoke sessions and tokens.
- **Hunt** for the same IOCs across all systems, and quarantine any further infected hosts.
- **Eradicate and recover:** remove the malware and persistence, patch the entry vector, and rebuild the machine from a trusted image if its integrity is uncertain.
- **Improve:** add the IOCs and detection rules (YARA, Sigma, SIEM) to monitoring, give the user security awareness training, and share the findings with the TI platform and relevant parties.

Question 4: Malware Detection Through Data Collection and Correlation

A university detects unusual processes on several computers, suspicious DNS requests, and unexpected outbound network connections. Explain how an analyst can collect and correlate endpoint logs, DNS records, firewall logs, and file hashes to determine whether the computers are infected with malware.

Introduction

A single odd process, DNS request or connection might be harmless, but the same pattern appearing in all of them on one host is strong evidence of infection. The analyst therefore collects data from each layer and correlates them by host, user, IP address and time.

Step 1: Data collection

Source	What to collect
Endpoint logs	Sysmon events (1 process creation, 3 network connection, 11 file creation, 13 registry change, 22 DNS query), Windows Security events (4688 process creation, 4624/4625 logons), PowerShell logs, EDR telemetry, installed software and autostart entries
DNS records	Resolver query logs: client, queried name, record type, response code, time; passive DNS for domain history
Firewall and proxy logs	Source and destination IP, port, protocol, bytes sent and received, session duration, allowed or blocked
File hashes	SHA-256 of suspicious executables from Sysmon (hash field), EDR or manual hashing, to compare across machines

Logs are forwarded to a central SIEM (Splunk or ELK), time-synchronised with NTP, normalised to common fields, and preserved so they cannot be altered.

Step 2: Analyse each data source

- **Endpoints:** look for unsigned processes, odd parent-child relationships and executables running from Temp or AppData; stack-count processes and hashes to see which appear on only a few machines.
- **DNS:** look for rare or newly registered domains, long or random-looking names (DGA or tunnelling), repeated NXDOMAIN responses and queries at regular intervals.
- **Firewall:** look for connections to rare external IPs, unusual ports, regular beacon timing, large uploads and connections at odd hours.
- **Hashes:** check each hash against VirusTotal and other threat-intelligence sources; the same unknown or malicious hash on several PCs points to one outbreak.

Step 3: Correlate the data

The aim is to build a chain for each computer:

Link in the chain	Evidence
1. Process	Unknown process (hash H) started at 02:14 on PC-17 by user X
2. DNS	PC-17 queried a rare domain at 02:14 shortly after the process started
3. Network	Firewall shows PC-17 connecting to the resolved IP, repeatedly every 60 seconds
4. Intelligence	The hash, domain and IP are flagged as malicious by threat-intelligence sources

The analyst joins the data on host and IP address, matches DNS answers to firewall destinations, and ties the network connection back to the process using Sysmon Event 3 (which records the process image and destination). The common hash, domain and IP across several computers confirm a shared infection.

Step 4: Decide

- **Likely infected** if a suspicious process, a malicious or rare DNS name and an outbound connection align in time on the same host, particularly with a known-bad hash or persistence.
- **Likely benign** if the process is signed, matches approved software and the destination belongs to a legitimate update service.
- Confirm borderline cases with a sandbox run, memory or disk inspection.

Step 5: Response

Isolate confirmed hosts, block the domains and IPs, remove the malware, search the whole network for the same hash and domains, and document the evidence and IOCs.

Question 5: Malware Investigation Using SIEM Tools

A financial institution's Security Information and Event Management (SIEM) system generates alerts about suspicious process execution, repeated failed logins, and unusual network connections from the same workstation. Describe how the security analyst can use SIEM capabilities to correlate these events, investigate the possible malware infection, and prioritize the incident.

Introduction

Three alerts from one workstation are individually moderate, but together they suggest an attack in progress: malware running, attempts to obtain other credentials, and communication with an outside server. The SIEM's ability to ingest, normalise, search, correlate and score events makes this visible as one incident.

Step 1: Correlate the events

- The SIEM groups alerts that share the same host, user, source IP and time window into one correlated incident.
- A correlation rule might read: "Suspicious process on host X, plus 5 or more failed logins from X to other systems, plus an outbound connection from X to a rare external IP, all within 30 minutes, equals High severity."
- The combined pattern fits a known attack chain: execution, then credential access (brute force or password spraying), then command-and-control and possible lateral movement.

Step 2: Investigate using SIEM capabilities

1. **Build a timeline** of every event for the workstation, from the first suspicious activity.
2. **Examine the process:** name, path, command line, parent, hash and signature from endpoint logs; check the hash against threat intelligence built into the SIEM.
3. **Examine the failed logins:** which accounts were targeted, which systems, whether any succeeded afterwards (Event 4625 followed by 4624), indicating lateral movement.
4. **Examine the network connections:** destination IPs and domains, ports, volume and regularity (beaconing), using firewall, proxy and DNS logs and geolocation enrichment.
5. **Search for the same indicators** across all hosts to find other infected machines.
6. **Use UEBA and dashboards** to compare the workstation and user with their normal behaviour.

Step 3: Prioritise the incident

Factor	Reason for high priority here
Asset criticality	A workstation in a financial institution may have access to payment, customer or core systems
Attack stage	Execution plus credential attacks plus C2 shows advanced progress, not just a scan
Threat-intelligence match	Known-bad hash or destination raises confidence
User privilege	If a privileged or finance user is involved, impact is greater
Spread	Evidence of successful logins to other systems increases severity
Regulatory exposure	Possible breach of financial data and mandatory reporting obligations

The SIEM assigns a risk score from these factors, placing the incident at the top of the analyst queue (for example Critical or High), de-duplicating the related alerts and opening a case.

Step 4: Response

- Isolate the workstation (manually or through SOAR), disable the involved accounts and block the malicious destinations.
- Collect memory and disk evidence, remove the malware, and rebuild the system if needed.
- Notify management and compliance teams as required, create new detection rules from the findings, and record the lessons learned.

Question 6: Malware Detection and Log Analysis Using Splunk

A company uses Splunk to monitor its network and endpoint logs. The security team suspects that malware is attempting to contact an external command-and-control server. Explain how Splunk can be used to search relevant logs, identify suspicious communication patterns, correlate events, and document evidence of possible malware activity.

Introduction

Splunk indexes machine data from many sources and lets analysts search it using the Search Processing Language (SPL). Its flexibility makes it well suited to finding the repeated, low-volume traffic typical of command-and-control (C2) communication.

Step 1: Data onboarding

- Install Universal Forwarders on endpoints and servers and send Windows event logs, Sysmon and PowerShell logs; ingest firewall, proxy, DNS and VPN logs into separate indexes.
- Use the Common Information Model (CIM) and add-ons so that fields such as src_ip, dest_ip, dest_domain, user and process are consistent across sources.

Step 2: Search for suspicious communication

Example SPL searches (index and field names are illustrative):

a) Beaconing: connections at regular intervals

```
index=firewall action=allowed
| sort 0 src_ip dest_ip _time
| streamstats current=f last(_time) as prev by src_ip dest_ip
| eval delta=_time-prev
| stats count avg(delta) as avg_gap stdev(delta) as dev by src_ip dest_ip
| where count>20 AND dev<5
```

b) Rare external destinations

```
index=firewall action=allowed | stats dc(src_ip) as hosts count by dest_ip
| where hosts<=2 | sort - count
```

c) Suspicious DNS (long names, possible tunnelling or DGA)

```
index=dns | eval qlen=len(query) | where qlen>50
| stats count by src_ip query
```

d) Which process made the connection (Sysmon Event 3)

```
index=sysmon EventCode=3 | stats count values(DestinationIp) by host, Image
```

e) Match against threat intelligence

```
index=proxy | lookup threat_intel_domains domain as dest_domain
  OUTPUT threat_name | where isnotnull(threat_name)
```

Step 3: Typical suspicious patterns

Pattern	Why it suggests C2
Regular beacon interval	Malware "checks in" at fixed or jittered intervals with small uniform packets
Rare or new destination	Only one or two hosts talk to it; often a newly registered domain
Unusual port or protocol	HTTP or custom traffic on non-standard ports
Long or random DNS names	DGA domains or DNS tunnelling

Pattern	Why it suggests C2
Non-browser process connecting out	For example a script host or an unknown executable contacting the internet

Step 4: Correlate events

The analyst pivots on host and time. Using stats or transaction on host, the results of the searches above are combined: process creation (Sysmon Event 1, Windows 4688), then the DNS query, then the outbound connection, and any preceding logon activity. Seeing the chain on the same host, within seconds of each other, turns separate observations into evidence of malware activity. A correlation search can then be saved and scheduled as an alert.

Step 5: Document the evidence

- Record each search with its SPL, time range, and results; save useful ones as reports and dashboards, and add an alert or notable event for continued monitoring.
- Export result tables (CSV or PDF) and take time-stamped screenshots, and generate hashes of exported files to protect integrity.
- Write a timeline with hosts, users, process names, hashes, domains, IPs and ATT&CK mapping, and keep a chain-of-custody note.
- Hand the IOCs to the response team for blocking and remediation.

Question 7: Malware Investigation Using the ELK Stack

An e-commerce company uses the ELK Stack (Elasticsearch, Logstash, and Kibana) to monitor web server logs, firewall records, and endpoint events. The security team notices repeated connections to suspicious domains and unusual file activity. Explain how the ELK Stack can support malware investigation through log collection, processing, searching, visualization, and correlation.

Introduction

The ELK Stack is an open-source platform for centralised logging and analysis. **Beats** collect data, **Logstash** processes it, **Elasticsearch** stores and indexes it, and **Kibana** searches and visualises it. Together they let the security team follow suspicious activity across web, network and endpoint data.

1. Log collection

- **Filebeat** ships web server and application logs; **Winlogbeat** ships Windows event and Sysmon logs; **Auditbeat** and **Packetbeat** capture file integrity, system and network activity; firewall logs arrive by syslog.
- Elastic Agent can also manage collection centrally.

2. Log processing (Logstash)

- **Input:** receives data from Beats or syslog.
- **Filter:** grok or dissect parses raw text into fields, date sets the event time, geoip adds location, and a translate or enrichment step tags known bad domains.
- **Output:** sends structured events to Elasticsearch.

A simplified pipeline:

```
input  { beats { port => 5044 } }
filter { grok { match => { "message" => "%{COMBINEDAPACHELOG}" } }
         geoip { source => "clientip" } }
output { elasticsearch { hosts => ["localhost:9200"] } }
```

Mapping the data to the Elastic Common Schema (ECS) gives consistent field names such as host.name, process.name, destination.domain and file.path, which makes correlation much easier.

3. Storage and searching (Elasticsearch and Kibana)

Elasticsearch indexes the events for fast full-text and field searches. In Kibana Discover, the analyst can query with KQL, for example:

```
destination.domain : "suspicious-domain.example"
event.category : "file" and event.action : ("creation" or "modification")
  and file.path : *\\Temp\\* and host.name : "WS-021"
```

4. Visualisation

- Bar charts of the top contacted domains and top hosts contacting them.
- Time-series charts or heat maps showing connection counts by hour to reveal beaconing or after-hours activity.
- Maps of external destinations (geo view), and tables of newly created executable files.
- For the web servers: charts of POST requests to upload paths, unusual response codes and user agents, which can expose web shells.

5. Correlation

- Kibana Security detection rules and **EQL sequences** link events in order, for example a Word process followed by PowerShell, followed by a network connection from the same host.

```
sequence by host.id with maxspan=5m
  [process where process.name == "powershell.exe"]
  [network where destination.domain == "suspicious-domain.example"]
```

- Pivoting on host, user, hash or domain connects the repeated domain connections to the unusual file activity, and a Timeline view shows the combined events in sequence.
- Machine-learning jobs flag anomalies, and rules can raise alerts by email or ticket.

Outcome

The team can confirm which hosts contacted the suspicious domains, identify the process and files responsible, check whether the web servers were abused, and then contain the infection, block the domains and save the dashboards and rules for future detection.

Question 8: Threat Hunting for Malware Activities

An organization's security team suspects that malware has infected an employee workstation but has not received any antivirus alerts. The workstation shows unusual CPU usage, unfamiliar processes, and connections to unknown external IP addresses. Describe a threat-hunting approach to investigate the workstation, identify suspicious behaviors, collect relevant IoCs, and recommend remediation measures.

Introduction

Antivirus relies mainly on known signatures, so it can miss new, packed, fileless or "living-off-the-land" malware. Threat hunting looks for behaviour instead of signatures. High CPU use and unknown outbound connections suggest possible cryptomining or a remote-access trojan.

Step 1: Hypothesis and preparation

Hypothesis: "The workstation runs an undetected malicious process that uses CPU resources and communicates with an external server." Preserve volatile data first and, if possible, work from the EDR console or a forensic copy so evidence is not altered.

Step 2: Hunt on the workstation

- **Processes:** use Task Manager, Process Explorer or Process Hacker to find the process with abnormal CPU use; check its path, parent, command line, signature and hash, and look for injected threads, hollowed processes and names that imitate system files (svch0st.exe).
- **Network:** run netstat -ano or TCPView to map each connection to its process ID; note remote IPs, ports (for example mining-pool ports) and connection regularity; check IP reputation and reverse DNS.
- **Persistence:** review Autoruns, Run keys, scheduled tasks, services, startup folders and WMI subscriptions.
- **Files:** inspect recently created or modified files in Temp, AppData and Downloads, and hash suspicious executables.
- **Logs:** review Sysmon, process-creation (4688) and PowerShell script-block (4104) logs for encoded or hidden commands.
- **Memory:** capture RAM (WinPmem, DumpIt) and analyse it with Volatility (pslist and psscan, netscan, malfind) to find hidden or injected code that is not visible on disk.
- **Enterprise view:** query the SIEM and EDR for the same process, hash and destination on other machines.

Step 3: Suspicious behaviours to look for

- Sustained high CPU at idle, especially by an unknown or misnamed process.
- Office applications or script hosts launching PowerShell, cmd or wscript.
- Executables running from user-writable folders; unsigned or recently created binaries.
- Regular connections to the same external IP, direct-to-IP traffic, or after-hours activity.

Step 4: Collect IoCs

IoC type	What is collected
File	SHA-256 hash, file name and path, creation time, signature status
Process	Process name, command line, parent process, mutexes
Network	External IPs, domains, ports, URLs, beacon interval
Persistence	Registry keys, scheduled tasks, services, startup entries

The hashes, IPs and domains are checked against threat intelligence and a sandbox to confirm maliciousness.

Step 5: Remediation

- Isolate the workstation, terminate the malicious process, remove files and persistence, and block the IoCs on the firewall, proxy, DNS and EDR.
- Re-image the machine if its integrity is uncertain, and reset the user's credentials.
- Sweep the organisation for the same indicators.
- Patch the entry vector, enable PowerShell and Sysmon logging, use application whitelisting, deploy or tune EDR, and train users.
- Convert the hunt's findings into permanent detection rules and document the investigation.

Question 9: Comparing Malware Analysis Tools Used in the IT Industry

A cybersecurity team needs to investigate a suspicious file and determine whether it contains malicious code. Compare static analysis tools, dynamic analysis tools, network traffic analyzers, and threat intelligence platforms in terms of their purpose and usefulness. Recommend an appropriate combination of tools for conducting a malware investigation.

Comparison

Category	Purpose	Example tools	Strengths	Limitations
Static analysis tools	Examine file structure, strings, imports and code without running it	PEStudio, strings/FLOSS, Detect It Easy, Ghidra, IDA, YARA	Safe; fast; reveals capabilities and embedded IOCs; finds known patterns	Packing and obfuscation hide intent; no runtime behaviour; needs skill
Dynamic analysis tools	Run the file in an isolated environment and record behaviour	Cuckoo, ANY.RUN, Joe Sandbox, Process Monitor, Regshot	Shows real file, registry, process and network actions; defeats simple packing	Risk if not isolated; malware may detect sandbox; time-consuming
Network traffic analyzers	Capture and inspect communication	Wireshark, Zeek, Suricata, FakeNet-NG, INetSim	Reveals C2 servers, protocols, data leaving the network; supports blocking rules	Encrypted traffic limits detail; shows only network behaviour
Threat intelligence platforms	Provide context on hashes, IPs, domains and actors	VirusTotal, MISP, AlienVault OTX, Recorded Future	Very fast triage; identifies family and related IOCs; shares knowledge	Unknown or new malware may not be listed; reliability varies; privacy if uploading files

Usefulness in an investigation

- Threat intelligence is the quickest first check and the best source of context.
- Static analysis is the safest way to understand the file in depth and extract early IOCs.
- Dynamic analysis confirms what the file really does when it runs.
- Network analysis shows who it talks to and what it sends, and supplies blocking indicators.

No single category is sufficient; each covers the weakness of another.

Recommended combination and workflow

1. **Triage:** compute the hash and check it in VirusTotal and the TIP.
2. **Static analysis:** PEStudio, strings/FLOSS and Detect It Easy for properties, imports and packing; Ghidra if deeper review is needed.
3. **Dynamic analysis:** run in a sandbox (Cuckoo or ANY.RUN) with Process Monitor and Regshot to observe changes.
4. **Network analysis:** capture with Wireshark or FakeNet-NG and confirm C2 domains, IPs and traffic patterns.
5. **Enrich and share:** pivot on discovered IOCs in the TIP, search the SIEM and EDR for infected systems, then update detections and write the report.

Selection criteria

The final choice also depends on safety, cost (open-source versus commercial), analyst skill, time available and the integration of tools with the existing SIEM and EDR environment.

Question 10: Malware Analysis Report and Incident Response

A company discovers a suspicious executable on an employee's computer. Initial analysis identifies an unfamiliar process, a modified system configuration, and communication with a suspicious external domain.

(The question as supplied ends here. It is answered as: how the analyst prepares the malware analysis report and carries out incident response.)

Introduction

The three findings (an unfamiliar process, a changed system configuration and traffic to a suspicious domain) indicate execution, persistence or defence evasion, and command-and-control. The response should follow a structured incident-response lifecycle (NIST: preparation, detection and analysis, containment, eradication and recovery, post-incident activity), and the findings must be documented in a malware analysis report.

Finding	Meaning	Action
Unfamiliar process	Malware executing, possibly injected or masquerading	Capture process and memory details; hash and analyse; terminate after evidence capture
Modified system configuration	Persistence, security settings disabled, or proxy or hosts file changed	Document the changes, restore from a known-good state, remove persistence
Communication with suspicious domain	Possible C2 or data exfiltration	Block domain and IP, review logs for other hosts and data sent

Incident-response process

1. **Detection and analysis:** confirm the incident, record the time and who found it, preserve evidence (memory, disk image, logs) with chain of custody, perform static and dynamic analysis, and check threat intelligence.
2. **Containment:** isolate the computer, block the domain, IP and hash across the organisation, and disable or reset the affected accounts.
3. **Eradication:** remove the executable, dropped files and persistence entries, reverse the configuration changes, patch the entry vector and search for other infected systems.
4. **Recovery:** restore the system from a clean image or backup, return it to service, and monitor it closely for reinfection.
5. **Post-incident activity:** hold a lessons-learned review, update controls and detection rules, and communicate with management and, where required, regulators or affected parties.

Structure of the malware analysis report

Section	Content
1. Executive summary	What was found, business impact, current status and key recommendations in plain language
2. Incident overview	How and when it was detected, affected user and system, scope
3. Sample details	File name, size, type, MD5, SHA-1, SHA-256, source (for example email attachment)
4. Static analysis findings	Strings, PE properties, packing, imports, signatures matched
5. Dynamic analysis findings	Process, file, registry and configuration changes; persistence; screenshots

Section	Content
6. Network analysis	Domains, IPs, ports, protocols, data sent, beacon behaviour
7. Indicators of Compromise	Table of hashes, domains, IPs, file paths, registry keys, mutexes
8. MITRE ATT&CK mapping	Techniques observed (for example execution, persistence, command-and-control)
9. Timeline	Sequence of events from delivery to containment
10. Impact and risk assessment	Systems and data affected, severity, confidence
11. Actions taken and recommendations	Containment and eradication steps, and short- and long-term improvements
12. Appendices	Tool output, logs, screenshots, YARA or Sigma rules

Recommendations

- **Immediate:** isolate and clean affected hosts, block IOCs, reset credentials.
- **Short term:** push IOCs and rules to SIEM, EDR, email gateway and DNS filter; scan all endpoints; patch and tighten email attachment filtering.
- **Long term:** security awareness and phishing training, least privilege, application whitelisting, regular backups and tested response drills.

Conclusion

A clear malware analysis report together with a disciplined incident-response process ensures the threat is understood, contained and removed, the evidence is preserved, and the organisation emerges with better detection and prevention.